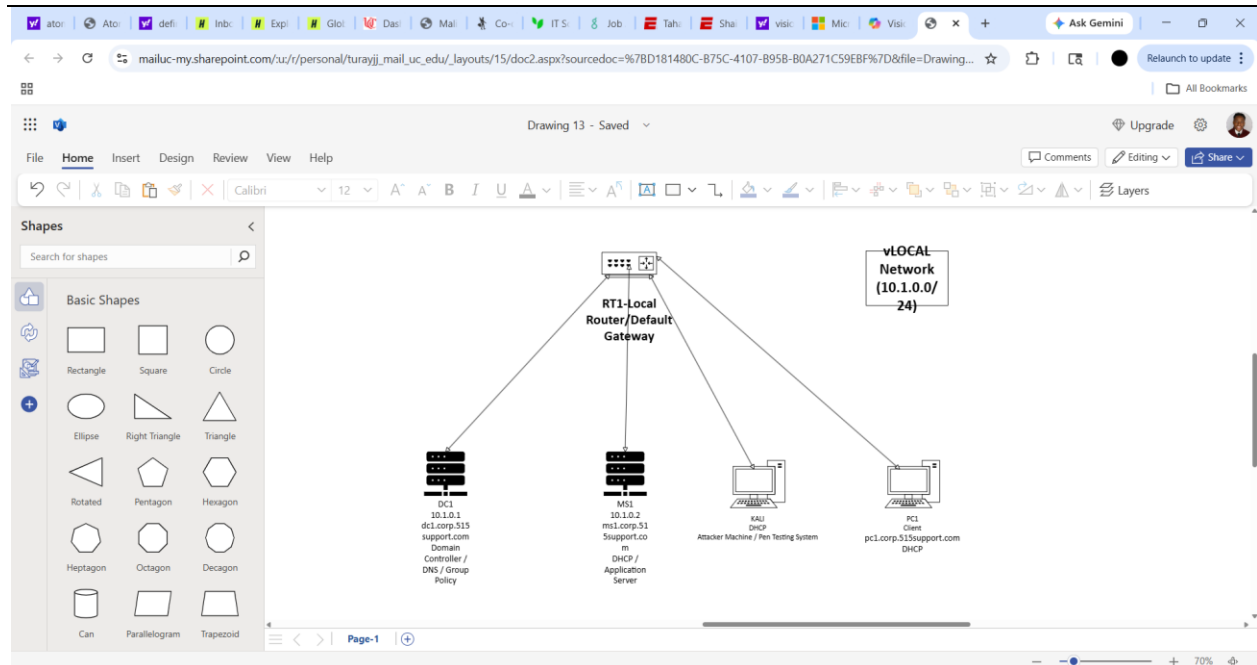


Network Security Lab Report

Lab Title: Malicious Software

Network Diagram(s)



System Information

VM Name	Operating System	IP Address	FQDN	Role/Purpose
RT1-Local	VyOS(Linux Router)	N/A	N/A	Routes traffic within the local lab network
DC1	Windows Server 2016	10.1.0.1	dc1.corp.515support.com	Domain controller, DNS, and Group Policy management
MS1	Windows Server 2016	10.1.0.2	ms1.corp.515support.com	DHCP server and internal services



KALI	Kali Linux	DHCP Assigned	N/A	Used to create payload and control infected system
PC1	Windows 10	DHCP Assigned	pc1.corp.515support.com	Target system used to simulate infection

Objective

- The objective of this lab was to understand how malicious software can be used to compromise a system and gain unauthorized access. This included exploring how attacks are carried out using social engineering techniques, such as tricking a user into downloading and executing a malicious file. The lab also focused on how payloads, like a reverse TCP connection, can be used to establish a backdoor and allow remote control of a system.

In addition, this lab demonstrated key security threats such as trojans and unauthorized remote access, along with how these attacks can spread within a network if not properly controlled. From a defense perspective, the lab highlighted security mechanisms like antivirus software and Group Policy, as well as mitigation techniques such as enforcing real-time protection and restricting user ability to disable security settings.

Overall, this lab connects to course concepts related to malware classification, attack methods, and system hardening, showing both how attacks occur and how they can be prevented in a network security environment.

Procedure

Environment Setup and System Startup:

-I started by reverting all virtual machines to their original state and powering them on in the correct order. I first powered on RT1-LOCAL, DC1, and MS1, then waited for services to fully start before powering on KALI and PC1. Once everything was running, I logged into PC1 and disabled Windows Defender real-time protection to make the system vulnerable for testing.

Creating the Malicious Payload (KALI):

-Next, I switched to the KALI machine and used the Social Engineering Toolkit (SET) to generate a payload. I selected the option to create a Windows reverse TCP Meterpreter payload and configured it using the IP address of the Kali system along with port 443. After generating the payload, I started the Metasploit listener so it would wait for a connection from the target system.

Preparing and Hosting the Payload:

-After creating the payload, I renamed the file to something that looked legitimate, "BubbleBlast2020.exe," to simulate a social engineering attack. I then hosted the file on the Kali machine using a Python web server so that it could be downloaded from the target system.

Delivering and Executing the Payload (PC1):

-On PC1, I opened a web browser and navigated to the Kali system's IP address to access the hosted file. I downloaded the executable and ran it. Nothing visibly happened, but the malware was executing in the background.

Verifying the Infection:

-To confirm the system was infected, I opened Command Prompt on PC1 and ran the netstat command. This showed an active connection to the Kali machine, indicating that a backdoor connection had been successfully established.

Gaining Remote Access (KALI):

-I returned to the Kali machine and confirmed that a Meterpreter session had been opened. I interacted with the session and was able to run commands, view processes, and access system files. This confirmed that I had remote control over the target system.

Applying Security Mitigation (DC1 & PC1):

-To mitigate the attack, I logged into DC1 and opened Group Policy Management. I modified the Default Domain Policy to prevent users from disabling Windows Defender real-time protection. After applying the policy, I went back to PC1 and ran `gpupdate /force` to enforce the changes.

Detecting and Removing the Malware:

-Once the policy was applied, Windows Defender automatically detected and removed the malicious file. I verified that the system was no longer compromised by running `netstat` again, which showed that the connection to Kali was no longer active.

Restoring the Lab Environment:

-Finally, I reverted all virtual machines back to their original state to reset the lab environment.

Discussion

- This lab helped me see how easily a system can be compromised when basic security protections are turned off. What stood out to me was how simple the attack actually was. Once the payload was created and run on PC1, nothing noticeable happened on the screen, but the system was already infected and connected back to the Kali machine.

When I checked the connection using `netstat`, it showed that the system was communicating with Kali in the background. Being able to go back to Kali and interact with the system through Meterpreter made it clear how much control an attacker can have without the user realizing it.

Another important takeaway was how quickly the system was secured once protections were enforced again. After applying Group Policy and re-enabling real-time protection, Windows Defender detected and removed the malware. This showed how important it is to have security controls in place instead of relying on users to manage them.

Overall, this lab connected well to what we've learned in class by showing both how malware attacks happen and how they can be prevented.

Lab Questions

1. Is there a legitimate reason as user would turn off their anti-virus protection? Explain why or why not.

- In most cases, there isn't a good reason for a regular user to turn off their antivirus protection. From what I saw in this lab, disabling it immediately made the system vulnerable and allowed the malware to run without being stopped. That alone shows how risky it is.

The only time it might make sense is for troubleshooting or if a program is being falsely flagged, but even then it should only be temporary and done carefully. It's not something users should be doing because it removes one of the main layers of protection on the system and makes it much easier for an attack to succeed.

2. What classification would you place on the payload we created? Explain your answer.

- I would classify the payload we created as a Trojan attack agent. It was disguised as a legitimate program ("BubbleBlast2020.exe"), which is a key characteristic of a trojan since it tricks the user into running it. From the user's perspective, it looked like a normal file, but in reality it was malicious.

Once it was executed, it didn't damage the system directly but instead created a backdoor connection to the Kali machine. That's why it also fits the attack agent category, because it allowed remote access and control over the system. From what I saw in the lab, its main purpose wasn't just to infect the system, but to give the attacker control after the infection.

3. What exactly was the netstat command showing when the malware was installed?

- When I ran the netstat command after installing the malware, it showed an active network connection between PC1 and the Kali machine. This connection was the backdoor that the payload created, allowing the infected system to communicate with the attacker's system.

From what I saw, it confirmed that the malware was running in the background and had successfully established a remote connection. This means the attacker would be able to send commands and control the system without the user noticing.

4. What category of malware did Windows Defender apply to the payload?

-Windows Defender classified the payload as a trojan. This makes sense because the file was disguised as a legitimate program but actually created a backdoor connection to the Kali machine. Once real-time protection was turned back on, Windows Defender detected the payload as a threat and removed it.